

МОДЕЛИРОВАНИЕ СЦЕНАРИЕВ АТАК КЛАССОВ «ПЕРЕПОЛНЕНИЕ БУФЕРА» И «ЗЛОУПОТРЕБЛЕНИЕ ПРИВИЛЕГИЯМИ» В КОРПОРАТИВНОЙ СЕТИ

В.П. Лось, Р.С. Лопатин, Е.С. Петрова, Д.А. Щеглова, А.М. Лебедев, Д.С. Покудин

Рассматриваются основные этапы построения сценариев на основе комбинации векторов атак и уязвимостей, связанных с типами ошибок CWE. Представляется методология этапов моделирования сценариев эксплуатации уязвимостей в корпоративных сетях для противодействия современным кибератакам. Применение классификаций CAPEC и баз данных, таких как БДУ ФСТЭК России, позволило систематизировать информацию о киберугрозах. Предложены примеры сценариев атак, включая «переполнение буфера» и «злоупотребление привилегиями», построенные в соответствии с MITRE ATT&CK. Данный подход позволяет спрогнозировать действия злоумышленников от возможных атак, обеспечивая при этом устойчивую работу корпоративных сетей.

Ключевые слова: переполнение буфера, злоупотребление привилегиями, тактики, техники, моделирование, сценарий.

Введение

Проблема защиты корпоративных сетей от компьютерных атак приобретает сегодня все большее значение [1], ибо современные организации сталкиваются регулярно с масштабными кибератаками, которые нацелены на их информационные ресурсы. Это объективно требует внедрения комплексных мер технической и организационно-правовой защиты для автоматизированных информационных систем (АИС) и телекоммуникационных сетей (ТКС). Где нужно учитывать сочетание различных векторов атак и уязвимостей в этих системах, которые злоумышленники могут использовать для их компрометации [2].

В связи с этим, специалистам, отвечающим за защиту АИС и ТКС, необходимо управлять сотнями известных злоумышленных сценариев и тысячами выявленных уязвимостей, что приводит к появлению десятков тысяч возможных комбинаций угроз. Каждая такая комбинация требует индивидуального подхода и специфического реагирования со стороны средств и органов защиты, что значительно усложняет процесс обеспечения безопасности [2]. Наиболее эффективным средством в этом случае является превентивное моделирование сценариев

кибератак, подкрепленное адекватным риск-анализом.

Исходные данные, необходимые и достаточные, для моделирования сценариев эксплуатации уязвимостей

Для моделирования сценариев необходимо сформировать пару «техника – уязвимость».

В качестве задающего вектора атаки выступает CAPEC-шаблон. CAPEC (Common Attack Pattern Enumeration and Classification) – это общедоступный справочник, содержащий классификацию и описание распространенных паттернов атак, предназначенный для анализа и понимания типичных методов эксплуатации уязвимостей в приложениях. Этот ресурс помогает специалистам по информационной безопасности эффективно выявлять угрозы и разрабатывать меры защиты, изучая способы, которые используют злоумышленники для реализации кибератак [3, 4].

CAPEC-шаблон представляет собой описание общих методов и средств, которые злоумышленники применяют для эксплуатации известных уязвимостей в корпоративных системах [4].

Использование нормативных возможностей ресурса CAPEC позволяет от заданного вектора атаки перейти к

рассмотрению используемых ею типов ошибок CWE к соответствующим им уязвимостям CVE/BDU [4].

Существенным недостатком системы CAPEC можно выделить тот факт, что информационные блоки о векторе атаке перегружены «водой», поэтому следует

отфильтровать информацию и занести ее в шаблонизированную описательную структуру (табл.1), позволяющую получить исчерпывающее представление об атаке и связанных с ней слабых мест и уязвимостей аппаратного и программного обеспечения.

Таблица 1

Шаблон паспорта вектора атаки

Наименование поля	Пояснение к полю	
Идентификатор системы CAPEC	В данное поле заносится условный идентификатор CAPEC и переведенное название атаки. (Примечание: перевод должен быть технически верным, грубый машинный перевод недопустим)	
Описание вектора атаки	В данное поле отражается необходимая и достаточная информация о векторе атаки.	
Тип атаки	В данном поле указывается к какому классу атаки относится вектор атаки	
Соотношение типа ошибки CWE и статуса типа ошибки CWE	В данную ячейку следует заносить CWE относящиеся к данному вектору атаки	В данную ячейку заносится статус CWE, который отображается на сайте CWE.org в поле «Vulnerability Mapping», а именно: - разрешен для использования в реальных уязвимостях (ALLOWED); - не рекомендован для использования в реальных уязвимостях (DISCOURAGED); - запрещен для использования в реальных уязвимостях (PROHIBITED).

В качестве связующего звена, позволяющего сопоставить связанные с вектором атаки уязвимости, выступает тип ошибки CWE [4]. Дающей возможность на первичном этапе получить выборку всех уязвимостей.

Выбор Банка данных угроз безопасности информации ФСТЭК России (далее – БДУ ФСТЭК России) в качестве основного датасета аргументируется содержанием в нем сведений как об отечественном, так и западном ПО. Дополнительно стоит отметить, что в БДУ ФСТЭК России приведены детально описанные паспорта уязвимостей, чем не могут похвастаться западные аналоги (такие как NIST NVD) [4, 5].

Детальность записей об уязвимостях дают возможным выбрать в качестве

эталонной структуры паспорта уязвимости структурное описание приведенное ФСТЭК России [5].

Отечественная база уязвимостей включает в себя не только сведения об уязвимостях ПО, но и описание угроз безопасности информации [5].

Для дальнейшего исследования были выбраны следующие структурные поля, которые достаточны и необходимы: идентификатор типа ошибки, метрики оценки критичности, степень подтверждения существования уязвимости, наличие эксплойта, участие в инцидентах и способ устранения.

Паспорт уязвимости, исходя из вышеописанного, имеет вид (табл. 2).

Таблица 2

Шаблон паспорта уязвимости

Наименование поля	Пояснение к полю
Идентификатор уязвимости	CVE: ****-****; Уязвимость ***, позволяющая ***
Идентификатор типа ошибки	CWE-***
Базовый вектор уязвимости	CVSS 3.0: AV:*/AC:*/PR:*/UI:*/S:*/C:*/I:*/A:*

Наименование поля	Пояснение к полю
Уровень опасности уязвимости	Низкий/ Средний/Высокий/Критический уровень опасности (базовая оценка CVSS 3.0 составляет ***)
Статус уязвимости	Подтверждена производителем/ Подтверждена в ходе исследований/ Потенциальная уязвимость
Наличие эксплойта	Существует/ Существует в открытом доступе/ Данные уточняются
Способ устранения	***
Участие в инцидентах	Да/Нет

Методика моделирования сценариев эксплуатации уязвимостей компьютерными атаками

Имея необходимые исходные данные, можно приступить к моделированию сценария. Для этого следует, опираясь на шаблон атаки, выделить наиболее характерные техники MITR ATT&CK и соотнести с уязвимостями выстроить

предположительную цепочку действий злоумышленника в рамках заданного шаблона CAPEC.

Суть заключается в том, что имеется множество уязвимостей, эксплуатация которых приводит к использованию той или иной техники, в результате чего формируется множество путей реализации атаки (рис. 1).

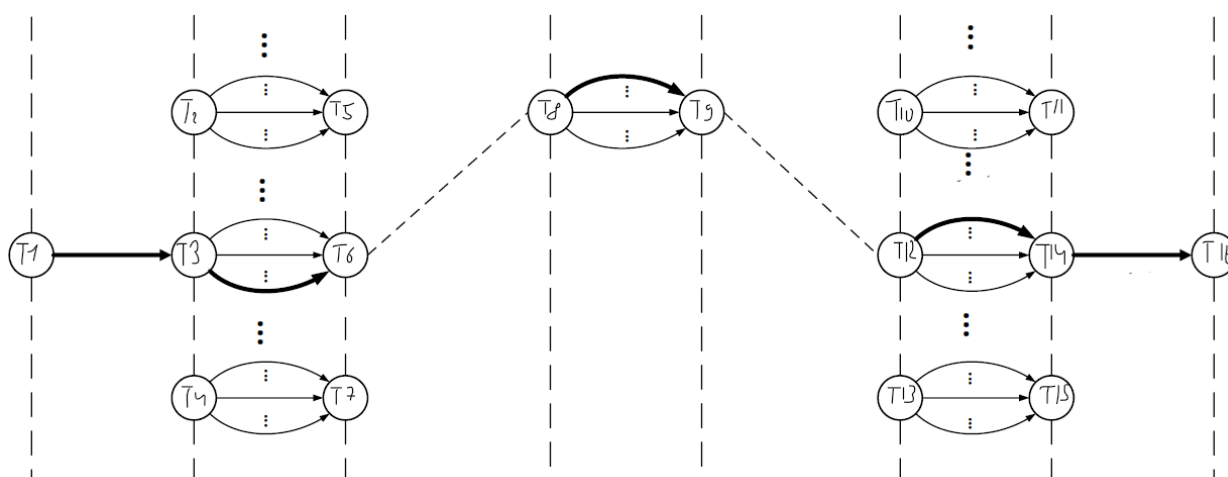


Рис. 1. Тактики реализации атаки

Для дальнейшего риск-анализа имеется возможным произвести отбор атак исходя из следующих критериев:

- максимальная вероятность (наиболее ожидаемый вариант);
- максимум ущерба (наихудший вариант);
- максимальный риск (рабочий вариант).

В результате может быть выделен один путь реализации атаки, с которым в дальнейшем и следует работать.

Моделирование сценариев атак класса «Переполнение буфера»

Переполнение буфера один из наиболее часто используемых векторов эксплуатации

уязвимостей. Последствия встречи злоумышленника с уязвимым к переполнению буфера кодом могут варьироваться от раскрытия конфиденциальных данных до полного захвата системы.

Подобные атаки, а также растущее число зарегистрированных уязвимостей в базах данных показывают необходимость изучать данные уязвимости и способы защиты от них.

В качестве представителя класса «Переполнение буфера» выступит CAPEC-540 «Избыточное чтение буфера», так как согласно материалам CQR (представляющей комплексные услуги по обеспечению ИТ-безопасности) данный тип переполнения

буфера является наиболее часто Паспорт CAPEC-540 имеет следующий встречающимся [7]. вид (табл. 3) [3].

Таблица 3

Паспорт вектора атаки CAPEC-540

Идентификатор системы CAPEC	CAPEC-540 Избыточное чтение буфера	
Описание вектора атаки	Злоумышленник атакует цель, предоставляя входные данные, которые заставляют приложение выполнять чтение за пределами допустимой области памяти буфера.	
Тип атаки	Переполнение буфера	
Соотношение типа ошибки CWE и статуса типа ошибки CWE	CWE-125: Чтение за границами буфера	Разрешен для использования в реальных уязвимостях

Далее необходимо выделить связанные с CAPEC-540 через CWE-125 уязвимости (рис. 2).

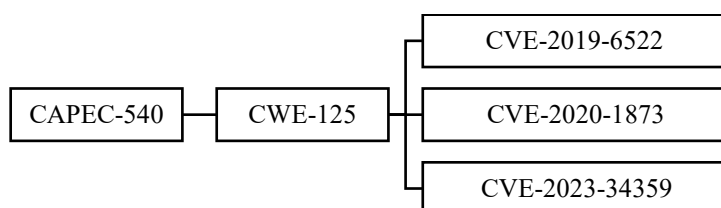


Рис. 2. Связанные с CAPEC – 540 уязвимости

Среднеквадратичная оценка критичности уязвимостей представлена в табл. 4.

Таблица 4

Среднеквадратичная оценка критичности уязвимостей для CAPEC-540

Уязвимость	Значение критичности
CVE-2019-6522	0.65
CVE-2020-1873	0.75
CVE-2023-34359	0.73

Получив среднеквадратичные оценки критичности уязвимостей, можно приступить к моделированию сценария атаки, где следует соотнести техники и тактики с уязвимостями для CAPEC-540 (табл. 5).

Таблица 5

Соотнесение техник и тактик с уязвимостями для CAPEC-540

Техника	Тактика	Уязвимости, эксплуатация которых приводит к технике
T1659: Content Injection	Первоначальный доступ	CVE-2019-6522
T1059: Command and Scripting Interpreter	Выполнение	CVE-2020-1873
T1203: Exploitation for Client Execution		CVE-2019-6522
T1562: Impair Defenses	Предотвращение обнаружения	CVE-2020-1873
T1003: OS Credential Dumping	Получение учетных данных	CVE-2019-6522
T1040: Network Sniffing	Изучение	CVE-2020-1873
T1113: Screen Capture	Сбор данных	CVE-2023-34359
T1056: Input Capture	Сбор данных	CVE-2019-6522

Продолжение табл. 5

Техника	Тактика	Уязвимости, эксплуатация которых приводит к технике
T1048: Exfiltration Over Alternative Protocol	Экспфильтрация данных	CVE-2020-1873 CVE-2023-34359
T1020: Automated Exfiltration		CVE-2019-6522 CVE-2023-34359
T1495: Firmware Corruption	Деструктивное воздействие	CVE-2019-6522
T1491: Defacement		CVE-2023-34359 CVE-2019-6522 CVE-2020-1873

Для наглядности визуализации на рис. 3-5 будет представлен сценарий атаки для CAPEC-540, где цифрами 1 – 20 обозначены уязвимости:

- 1) CVE-2019-6522;
- 2) CVE-2020-1873;
- 3) CVE-2019-6522;
- 4) CVE-2020-1873;
- 5) CVE-2019-6522;
- 6) CVE-2023-34359;
- 7) CVE-2020-1873;
- 8) CVE-2023-34359;

- 9) CVE-2019-6522;
- 10) CVE-2020-1873;
- 11) CVE-2023-34359;
- 12) CVE-2019-6522;
- 13) CVE-2020-1873;
- 14) CVE-2023-34359;
- 15) CVE-2019-6522;
- 16) CVE-2023-34359;
- 17) CVE-2019-6522;
- 18) CVE-2023-34359;
- 19) CVE-2019-6522;
- 20) CVE-2023-34359.

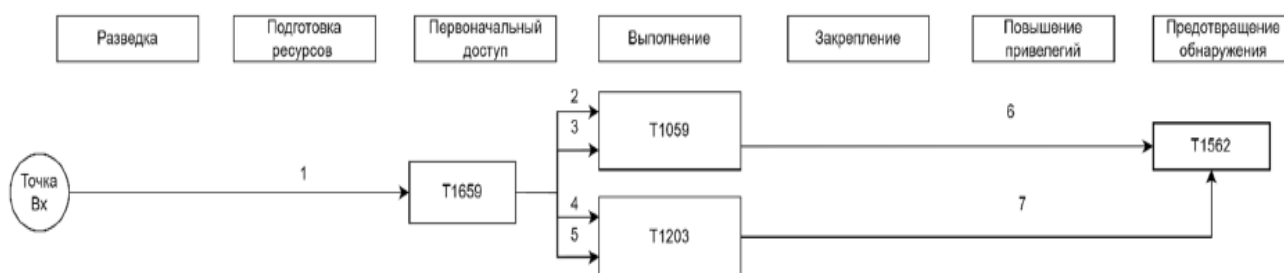


Рис. 3. Сценарий атаки CAPEC-540

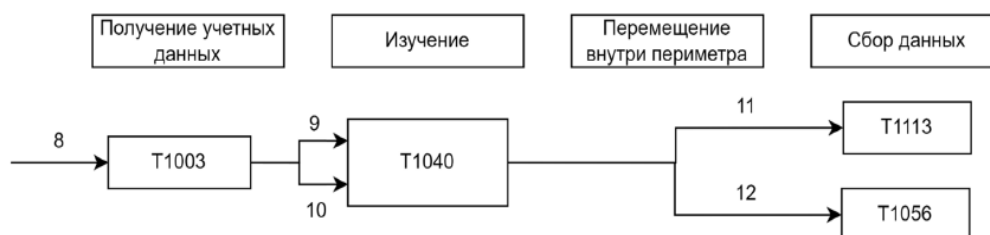


Рис. 4. Сценарий атаки CAPEC-540 (продолжение)



Рис. 5. Сценарий атаки CAPEC-540 (продолжение)

Для дальнейшего риск-анализа следует произвести выборку варианта реализации атаки по следующему критерию: максимальный риск.

Произведя выборку, получим путь реализации атаки с максимальным риском, с которым в дальнейшем и будем работать.

У каждого из сценариев имеются разветвления, поэтому разобьем каждый сценарий на несколько подсценариев по количеству имеющихся веток. Каждый подсценарий разобьем на микромодел. Для каждой микромодел отметим вероятность уязвимости, которая будет проэксплуатирована для перехода к следующей технике, и укажем ущерб, наносимый системе.

Расчет вероятности успеха единичной атаки вычисляется по следующей формуле (1):

$$P_i = \frac{\overline{K_i}}{\sum_i \overline{K_i}}, \quad (1)$$

где K_i - критичной i -той уязвимости.

Ущерб единичной атаки вычисляется следующим образом (2):

$$U = 1 - (1 - U_k)(1 - U_d)(1 - U_c), \quad (2)$$

где U_k – ущерб конфиденциальности,

U_d – ущерб доступности,

U_c – ущерб целостности.

Формула (3), позволяет произвести оценку риска возникающего при реализации избранного сценария атаки CAPEC-540:

$$\text{Risk} = \prod_i p_i \times \sum_j U_j, \quad (3)$$

где p_i – вероятность эксплуатации j -ой уязвимости посредством реализации техники T_i ;

U – ущерб, наносимый атакуемой системе в результате эксплуатации уязвимости CVE_j в ходе реализации техники T_i .

Для начала разобьем сценарий атаки для CAPEC-540 на микромодел (табл. 6-19, рис. 6-19).

Разбиение на микромодел дает произвести более внимательную оценка вероятности успеха и ущерба уязвимостей на конкретном участке проведения общей атаки.

Таблица 6

Вероятность эксплуатации единичной уязвимости и ущерб для микромодел № 1

№	Уязвимость	Вероятность успеха	Ущерб
1	CVE-2019-6522	1	0,75



Рис. 6. Микромодель № 1 для CAPEC-540

Таблица 7

Вероятность эксплуатации единичной уязвимости и ущерб для микромодели № 2

№	Уязвимость	Вероятность успеха	Ущерб
2	CVE-2020-1873	0,54	0,5
3	CVE-2019-6522	0,46	0,75

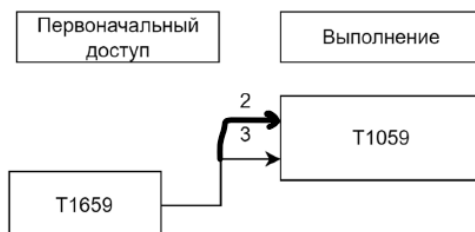


Рис. 7. Микромодель № 2 для CAPEC-540

Таблица 8

Вероятность эксплуатации единичной уязвимости и ущерб для микромодели № 3

№	Уязвимость	Вероятность успеха	Ущерб
4	CVE-2020-1873	0,54	0,5
5	CVE-2019-6522	0,46	0,75

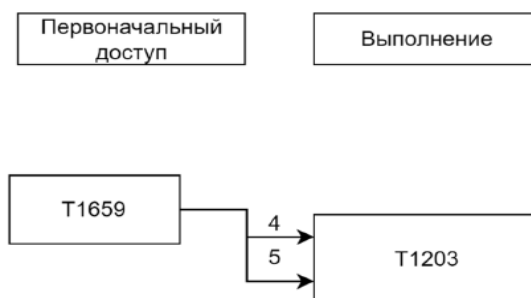


Рис. 8. Микромодель № 3 для CAPEC-540

Таблица 9

Вероятность эксплуатации единичной уязвимости и ущерб для микромодели № 4

№	Уязвимость	Вероятность успеха	Ущерб
6	CVE-2023-34359	1	0,5

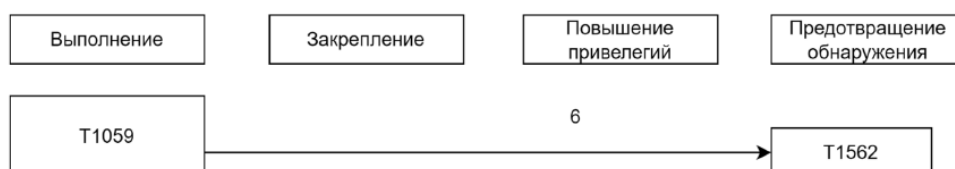


Рис. 9. Микромодель № 4 для CAPEC-540

Таблица 10

Вероятность эксплуатации единичной уязвимости и ущерб для микромодели № 5

№	Уязвимость	Вероятность успеха	Ущерб
7	CVE-2020-1873	1	0,5

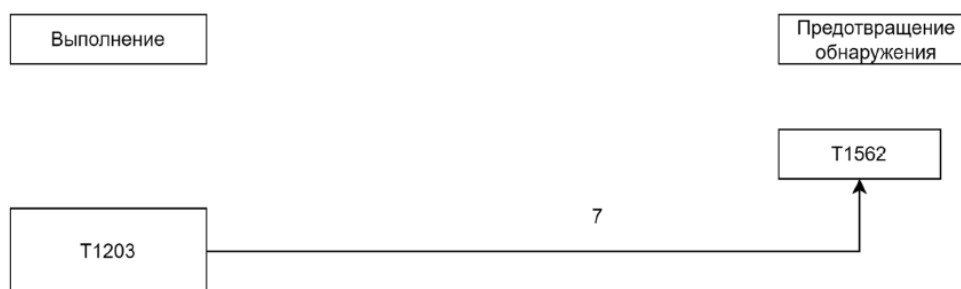


Рис. 10. Микромодель № 5 для CAPEC-540

Таблица 11

Вероятность эксплуатации единичной уязвимости и ущерб для микромодели № 6

№	Уязвимость	Вероятность успеха	Ущерб
8	CVE-2023-34359	1	0,5

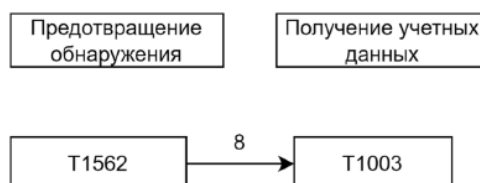


Рис. 11. Микромодель № 6 для CAPEC-540

Таблица 12

Вероятность эксплуатации единичной уязвимости и ущерб для микромодели № 7

№	Уязвимость	Вероятность успеха	Ущерб
9	CVE-2019-6522	0,47	0,75
10	CVE-2020-1873	0,53	0,5

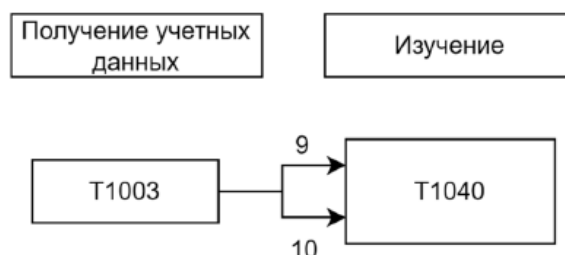


Рис. 12. Микромодель № 7 для CAPEC-540

Таблица 13

Вероятность эксплуатации единичной уязвимости и ущерб для микромодели № 8

№	Уязвимость	Вероятность успеха	Ущерб
11	CVE-2023-34359	1	0,5



Рис. 13. Микромодель № 8 для CAPEC-540

Таблица 14

Вероятность эксплуатации единичной уязвимости и ущерб для микромодели № 9

№	Уязвимость	Вероятность успеха	Ущерб
12	CVE-2019-6522	1	0,75



Рис. 14. Микромодель № 9 для CAPEC-540

Таблица 15

Вероятность эксплуатации единичной уязвимости и ущерб для микромодели № 10

№	Уязвимость	Вероятность успеха	Ущерб
13	CVE-2020-1873	0,51	0,5
14	CVE-2023-34359	0,49	0,5



Рис. 15. Микромодель № 10 для CAPEC-540

Таблица 16

Вероятность эксплуатации единичной уязвимости и ущерб для микромодели № 11

№	Уязвимость	Вероятность успеха	Ущерб
15	CVE-2019-6522	0,47	0,75
16	CVE-2023-34359	0,53	0,5

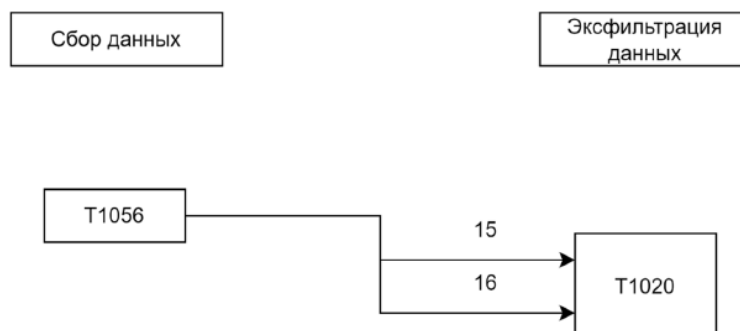


Рис. 16. Микромодель № 11 для CAPEC-540

Таблица 17

Вероятность эксплуатации единичной уязвимости и ущерб для микромодели № 12

№	Уязвимость	Вероятность успеха	Ущерб
17	CVE-2019-6522	1	0,75

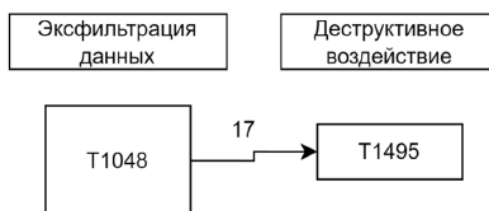


Рис. 17. Микромодель № 12 для CAPEC-540

Таблица 18

Вероятность эксплуатации единичной уязвимости и ущерб для микромодели № 13

№	Уязвимость	Вероятность успеха	Ущерб
18	CVE-2023-34359	1	0,5



Рис. 18. Микромодель № 13 для CAPEC-540

Таблица 19

Вероятность эксплуатации единичной уязвимости и ущерб для микромодели № 14

№	Уязвимость	Вероятность успеха	Ущерб
19	CVE-2019-6522	0,47	0,75
20	CVE-2023-34359	0,53	0,5



Рис. 19. Микромодель № 14 для CAPEC-540

Как видно из приведенного выше дробления общего сценария на 6 более мелких подсценариев, на каждом подсценарии выделяются значительные риски, а затем среди них находится максимальный и он непосредственно наносится на общий сценарий и впоследствии регламентация защиты будет производиться для этого выделенного пути.

Самый большой риск из всех возможных имеет путь: T1659 (CVE-2019-6522) -> T1203 (CVE-2020-1873) -> T1562 (CVE-2020-1873) -> T1003 (CVE-2023-34359) -> T1040 (CVE-2020-1873) -> T1113 (CVE-2023-34359) -> T1048 (CVE-2020-1873) -> T1495 (CVE-2019-6522) (Risk: 0.6568).

Отообразим этот путь на общем сценарии (рис. 20, 21).



Рис. 20. Сценарий атаки CAPEC-540 с выделенным путем по максимальному значению риска



Рис. 21. Сценарий атаки CAPEC-540 с выделенным путем по максимальному значению риска (продолжение)

Приведенный выше риск-анализ показал, что, своевременно рассчитывая риски реализации обнаруженных угроз можно спрогнозировать и адаптировать стратегию защиты организации, в условиях стремительно меняющегося ландшафта угроз, что позволяет ликвидировать или минимизировать «внезапный удар» злоумышленника и нивелировать дополнительные затраты, в случае успешности атаки если же не был проведен качественный и своевременный риск-анализ.

Описанное выше показывает, что Нарушение информационной безопасности может привести к многочисленным и серьезным последствиям, затрагивающим как организации, так и отдельных пользователей. При утечке конфиденциальной информации возможны финансовые потери, связанные с восстановлением утраченных данных и репутационными рисками. Ущерб для репутации может означать потерю доверия со

стороны клиентов и партнеров, что в свою очередь усложняет привлечение новых пользователей и может привести к снижению доходов.

Кроме того, атаки киберпреступников могут вызвать сбои в работе систем, что затрудняет выполнение бизнес-процессов и может привести к задержкам в производстве или оказании услуг. Также существует риск юридических последствий, если произошедшее нарушение повлечет за собой несоответствие требованиям законодательства по защите данных.

В отличие от аналогов, впервые аккумулированы экспертные и статистические метрики частот реализации атак класса «Переполнение буфера» и критичности уязвимостей защищаемых корпоративных систем, что позволяет создать база данных метрик атак класса «Переполнение буфера» и уязвимостей защищаемых корпоративных систем

являющихся практической основой для риск-калькуляции единичных вторжений, а также сформированная база метрик открыта для ее расширения на другие атакуемые объекты и для многовариантного анализа корреляций входящих в нее данных.

Моделирование сценариев атак класса «Злоупотребление привилегиями»

«Злоупотребление привилегиями» можно описать следующим образом: злоумышленник может использовать функции цели, которые должны быть зарезервированы для привилегированных пользователей или администраторов, но

доступны для использования учетными записями с более низкими или непривилегированными правами. Доступ к конфиденциальной информации и функциям должен контролироваться, чтобы гарантировать, что только авторизованные пользователи смогут получить доступ к этим ресурсам.

Наиболее «ярко» класс «Злоупотребление привилегиями» характеризует CAPEC-650 «Загрузка веб-оболочки на веб-сервер», это подтверждают материалы CQR [8].

Паспорт CAPEC-650 имеет следующий вид (табл. 20) [3].

Таблица 20

Паспорт вектора атаки CAPEC-650

Идентификатор системы CAPEC	CAPEC-650 Загрузка веб-оболочки на веб-сервер	
Описание вектора атаки	Используя недостаточные расширения, злоумышленник может загрузить веб-оболочку на веб-сервер таким образом, чтобы она могла выполняться удаленно. Эта оболочка может обладать различными возможностями, выступая в качестве «шлюза» к базовому веб-серверу.	
Тип атаки	Злоупотребление привилегиями	
Соотношение типа ошибки CWE и статуса типа ошибки CWE	CWE-287: Неправильная аутентификация	Не рекомендован для использования в реальных уязвимостях

Посредством типа ошибки CWE-287 с CAPEC-650 связаны следующие уязвимости (рис. 22).

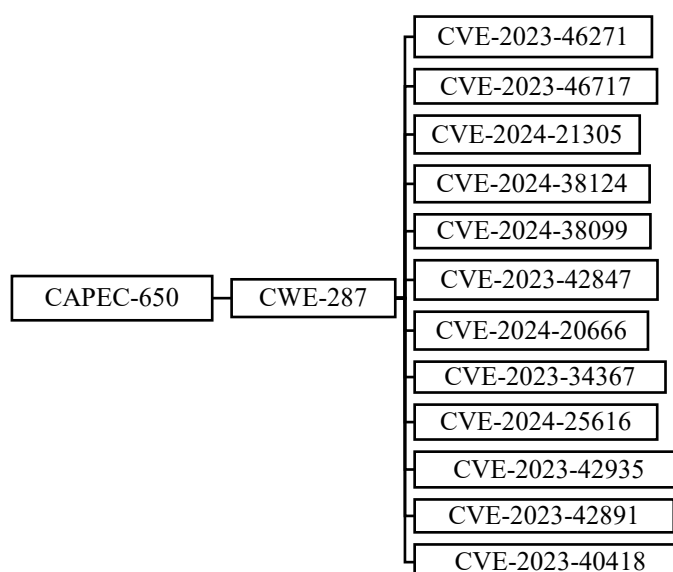


Рис. 22. Связанные с CAPEC-650 уязвимости

Среднеквадратичная оценка критичности уязвимостей представлена в табл. 21.

Таблица 21

Среднеквадратичная оценка критичности уязвимостей для CAPEC-650

Уязвимость	Значение критичности
CVE-2024-38124	0.72457
CVE-2024-38099	0.65611
CVE-2023-46271	0.75778
CVE-2023-46717	0.56332
CVE-2024-25616	0.41062
CVE-2023-42935	0.60546
CVE-2022-48618	0.72006
CVE-2024-22394	0.78129
CVE-2024-20666	0.62562
CVE-2024-21305	0.47236
CVE-2023-42891	0.54932
CVE-2023-42847	0.73349
CVE-2023-40418	0.56104
CVE-2023-34367	0.53881
CVE-2023-28963	0.57828

Получив среднеквадратичные оценки и тактики с уязвимостями для CAPEC-650 критичности уязвимостей, можно приступить (табл. 22). к моделированию сценария атаки. Перед моделированием следует соотнести техники

Таблица 22

Соотнесение техник и тактик с уязвимостями для CAPEC-650

Тактика	Техника	Уязвимости, эксплуатация которых приводит к технике
Первоначальный доступ	Exploit Public-Facing Application (T1190)	CVE-2024-38124 CVE-2023-46271
Выполнение	Command and Scripting Interpreter: PHP (T1059.005)	CVE-2024-25616
	Shared Modules (T1072)	CVE-2024-21305
	Exploitation for Execution (T1203)	CVE-2024-22394
Закрепление	Web Shell (T1505.003)	CVE-2023-42847 CVE-2023-42891
Обнаружение	File and Directory Discovery (T1083)	CVE-2023-34367
Предотвращение обнаружения	Modify Registry (T1112)	CVE-2023-40418
Сбор данных	Data from Local System (T1005)	CVE-2023-34367
Деструктивное воздействие	Data Destruction (T1485)	CVE-2024-22394 CVE-2024-38124

Для наглядности и визуализации на рис. 23 представлен сценарий атаки для CAPEC-650.

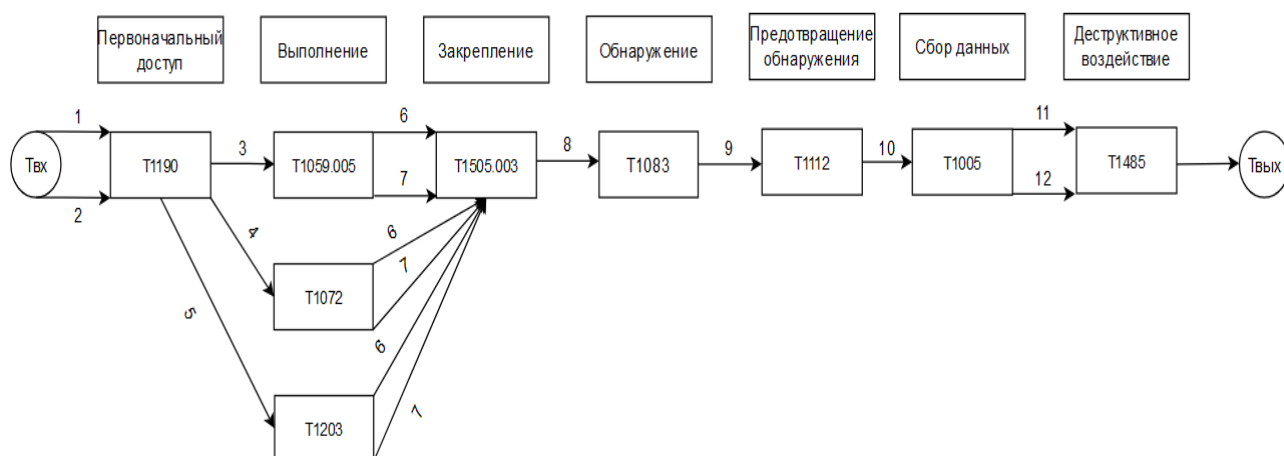


Рис. 23. Сценарий атаки CAPEC – 650

Для обозначения уязвимостей используем следующие сокращения:

- 1) CVE-2024-38124;
- 2) CVE-2023-46271;
- 3) CVE-2024-25616;
- 4) CVE-2024-21305;
- 5) CVE-2024-22394;
- 6) CVE-2023-42847;
- 7) CVE-2023-42891;
- 8) CVE-2023-34367;

- 9) CVE-2023-40418;
- 10) CVE-2023-34367;
- 11) CVE-2024-22394;
- 12) CVE-2024-38124.

Разобьем сценарий атаки для CAPEC-650 на микромоделей (табл. 23-31, рис. 24-34).

Разбиение на микромоделей дает произвести более внимательную оценку вероятности успеха и ущерба уязвимостей на конкретном участке проведения общей атаки.

Таблица 23

Вероятность эксплуатации единичной уязвимости и ущерб для микромоделей 1 для сценария CAPEC-58

№	Уязвимость	Вероятность успеха	Ущерб
1	CVE-2024-38124	0.48	0.875
2	CVE-2023-46271	0.52	0.875

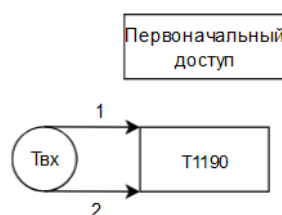


Рис. 24. Микромодель 1 для CAPEC-650

Таблица 24

Вероятность эксплуатации единичной уязвимости и ущерб для микромоделей 2 для сценария CAPEC-58

№	Уязвимость	Вероятность успеха	Ущерб
1	CVE-2024-25616	1	0.2



Рис. 25. Микромодель 2 для CAPEC-650

Таблица 25

Вероятность эксплуатации единичной уязвимости и ущерб для микромодели 3 для сценария CAPEC-650

№	Уязвимость	Вероятность успеха	Ущерб
1	CVE-2024-21305	1	0.5



Рис. 26. Микромодель 3 для CAPEC-650

Таблица 26

Вероятность эксплуатации единичной уязвимости и ущерб для микромодели 4 для сценария CAPEC-650

№	Уязвимость	Вероятность успеха	Ущерб
1	CVE-2024-22394	1	0.5



Рис. 27. Микромодель 4 для CAPEC-650

Таблица 27

Вероятность эксплуатации единичной уязвимости и ущерб для микромоделей 5, 6 и 7 для сценария CAPEC-650

№	Уязвимость	Вероятность успеха	Ущерб
1	CVE-2023-42847	0.50447	0.5
2	CVE-2023-42891	0.49553	0.5



Рис. 28. Микромодель 5 для CAPEC-650



Рис. 29. Микромодель 6 для CAPEC-650



Рис. 30. Микромодель 7 для CAPEC-650

Таблица 28
Вероятность эксплуатации единичной уязвимости и ущерб для микромодели 8 для сценария CAPEC-650

№	Уязвимость	Вероятность успеха	Ущерб
1	CVE-2023-34367	1	0.36



Рис. 31. Микромодель 8 для CAPEC-650

Таблица 29
Вероятность эксплуатации единичной уязвимости и ущерб для микромодели 9 для сценария CAPEC-650

№	Уязвимость	Вероятность успеха	Ущерб
1	CVE-2023-40418	1	0.5



Рис. 32. Микромодель 9 для CAPEC-650

Таблица 30

Вероятность эксплуатации единичной уязвимости и ущерб для микромодели 10 для сценария CAPEC-650

№	Уязвимость	Вероятность успеха	Ущерб
1	CVE-2023-34367	1	0.36



Рис. 33. Микромодель 10 для CAPEC-650

Таблица 31

Вероятность эксплуатации единичной уязвимости и ущерб для микромодели 11 для сценария CAPEC-650

№	Уязвимость	Вероятность успеха	Ущерб
1	CVE-2024-22394	0.49	0.5
2	CVE-2024-38124	0.51	0.875

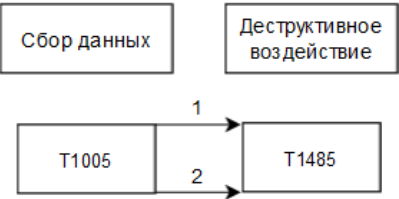


Рис. 34. Микромодель 11 для CAPEC-650

Для данного сценария атаки получилось 3 подсценария.

Наибольший риск: T1190 (CVE-2023-46271) -> T1203 (CVE-2024-22394) -> T1505.003 (CVE-2023-42847) -> T1083 (CVE-2023-34367) -> T1112 (CVE-2023-40418) ->

T1005 (CVE-2023-34367) -> T1485 (CVE-2024-38124) (Risk: 0.5310).

Отообразим этот путь на общем сценарии (рис. 35).

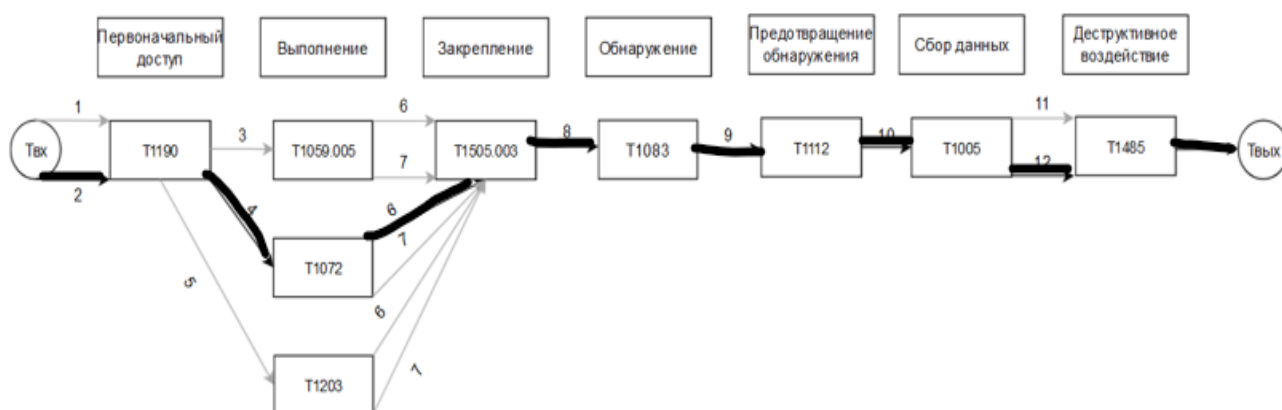


Рис. 35. Сценарий атаки CAPEC-650 с выделенным путем по максимальному значению риска

Проведённое исследование демонстрирует, что улучшение безопасности корпоративных сетей от кибератак типа «злоупотребление привилегиями» требует комплексного подхода, включающего оценку и управление рисками успешности атак. Представленная в статье методология оценки рисков даёт возможность количественно определить вероятность и потенциальный ущерб от таких атак, а также выбрать наиболее эффективные способы их предотвращения.

Предложенная методология оценки и управления рисками успешности кибератак типа «злоупотребление привилегиями» является действенным инструментом для обеспечения безопасности корпоративных сетей. Внедрение предложенных мер защиты способствует повышению устойчивости сетей к таким атакам и снижению связанных с ними рисков.

В дальнейшем исследования в этой области могут быть направлены на разработку более совершенствованных методов оценки и управления рисками, а также на изучение новых типов кибератак и разработку соответствующих мер защиты.

Заключение

Проведенное исследование подтвердило высокую значимость моделирования сценариев эксплуатации уязвимостей для обеспечения информационной безопасности корпоративных сетей. Анализ показал, что использование пар «вектор атаки – уязвимость» в сочетании с классификациями CAPEC и CWE позволяет эффективно выявлять критически опасные уязвимости, а также разрабатывать регламентированные

меры противодействия кибератакам на основе сценариев.

Новизна заключается в том, что исключительно для атак класса «переполнение буфера» и «злоупотребление привилегиями» впервые предложена графовая локализация, иллюстрирующая корреляцию их с уязвимостями защищаемых корпоративных систем.

Практическая ценность видится в том, что роца графов-деревьев, практически отражает географию причинно-следственных связей пар «атака-уязвимость» в проектной деятельности защиты корпоративных систем от атак класса «переполнение буфера» и «злоупотребление привилегиями».

Методика построения сценариев, основанная на последовательности этапов MITRE ATT&CK, обеспечивает структурированность подхода, что способствует улучшению прогнозирования и минимизации последствий атак. Примеры сценариев эксплуатации, такие как атаки на основе «переполнения буфера» и «злоупотребления привилегиями», наглядно демонстрируют важность комплексного анализа угроз для создания устойчивой системы защиты.

На основе методологии оценки рисков разработана система регулирования рисков, которая включает в себя технические, организационные меры безопасности. Технические меры включают использование безопасных языков программирования, средств контроля потока данных, а также внедрение межсетевых экранов и систем обнаружения вторжений. Организационные меры предусматривают обучение персонала мерам безопасной работы.

Таким образом, использованная в данной работе методология оценки и регулирования рисков успешности кибератак класса «Переполнение буфера» является эффективным инструментом обеспечения безопасности корпоративных сетей. Реализация предложенных мер безопасности позволяет повысить устойчивость сетей к подобным атакам и минимизировать связанные с ними риски.

Дальнейшие исследования в этой области могут быть сосредоточены на разработке более совершенных методов оценки и регулирования рисков, а также на изучении новых типов кибератак и разработке соответствующих мер противодействия, а также расширить применение предложенных подходов на автоматизированные системы управления корпоративных сетей. Такой подход позволит усилить защиту информационного пространства и минимизировать риски, связанные с эксплуатацией уязвимостей.

Список литературы

1 Моделирование компьютерных атак на распределенную информационную систему / А. А. Корниенко, А. Б. Никитин, С. В. Диасамидзе, Е. Ю. Кузьменкова // Известия ПГУПС, 2018. В. № 4. С. 613-615.

2 Организационно-правовая защита сетей / Г. А. Остапенко, Д. В. Щербакова, А. О. Калашников и др.; под ред. Академика РАН Д. А. Новикова. М.: Горячая линия Телеком, 2023. 228с.

3 The Common Attack Pattern Enumeration and Classification (CAPEC). URL: <https://capec.mitre.org> (дата обращения: 10.07.2025).

4 Остапенко Г.А. Формализация знаний и данных кибератак и уязвимостей / Г.А. Остапенко, А.П. Васильченко, А.А. Остапенко, Д.С. Покудин [и другие] // Информация и безопасность. 2024. Т. 27. Вып. 2. С. 231-238.

5 Банк данных угроз безопасности информации ФСТЭК. URL: <https://bdu.fstec.ru/threat> (дата обращения: 10.07.25).

6 MITRE ATT&CK. URL: <https://attack.mitre.org/matrices/enterprise> (дата обращения: 10.07.2025).

7 Переполнение буфера. URL: <https://cqr.company/ru/web-vulnerabilities/file-upload-vulnerabilities> (дата обращения: 10.07.2025).

8 Уязвимости при загрузке файлов. URL: <https://cqr.company/ru/web-vulnerabilities/file-upload-vulnerabilities> (дата обращения: 10.07.2025).

Российский государственный гуманитарный университет
Russian State University for the Humanities

Воронежский государственный технический университет
Voronezh State Technical University

Поступила в редакцию 17.07.2025

Информация об авторах

Лось Владимир Павлович – д-р воен. наук, профессор, Российский государственный гуманитарный университет, e-mail: los.vp@rea.ru

Лопатин Роман Сергеевич – канд. техн. наук, доцент, Воронежский государственный технический университет, e-mail: lopatinr@mail.ru

Петрова Елена Сергеевна – старший преподаватель, Воронежский государственный технический университет, e-mail: lenoks.sokolova@mail.ru

Щеглова Дарья Александровна – студент, Воронежский государственный технический университет, e-mail: dasha.shcheglova.00@mail.ru

Лебедев Антон Михайлович – студент, Воронежский государственный технический университет, e-mail: anton05102001@mail.ru

Покудин Данила Сергеевич – аспирант, Воронежский государственный технический университет, e-mail: danila.pokudin@inbox.ru

MODELING CLASS ATTACK SCENARIOS "BUFFER OVERFLOW" AND "ABUSE OF PRIVILEGES" IN THE CORPORATE NETWORK

V.P. Los, R.S. Lopatin, E.S. Petrova, D.A. Shcheglova, A.M. Lebedev, D.S. Pokudin

The main stages of building scenarios based on a combination of attack vectors and vulnerabilities related to CWE error types are considered. The methodology of the stages of modeling scenarios for exploiting vulnerabilities in corporate networks to counter modern cyber-attacks is presented. The use of CAPEC classifications and databases, such as the database of the FSTEC of Russia, made it possible to systematize information about cyber threats. Examples of attack scenarios are proposed, including "buffer overflow" and "privilege abuse", built in accordance with MITRE ATT&CK. This approach allows you to predict the actions of intruders from possible attacks, while ensuring the stable operation of corporate networks.

Keywords: attack vector, vulnerability, scenario, cyberattack, corporate network.

Submitted 17.07.2025

Information about the authors

Vladimir P. Los – Dr. Sc. (Military), Professor, Russian State University for the Humanities, e-mail: los.vp@rea.ru

Roman S. Lopatin – Cand. Sc. (Technical), Associate Professor, Voronezh State Technical University, e-mail: lopatinr@mail.ru

Elena S. Petrova – senior lecturer, Voronezh State Technical University, e-mail: lenoks.sokolova@mail.ru

Daria A. Shcheglova – student, Voronezh State Technical University, e-mail: dasha.shcheglova.00@mail.ru

Anton M. Lebedev – student, Voronezh State Technical University, e-mail: anton05102001@mail.ru

Danila S. Pokudin – postgraduate student, Voronezh State Technical University, e-mail: danila.pokudin@inbox.ru